

NexaCore Security Policy

Version 5.3 | Enterprise Security Baseline

Owner: Security Engineering Effective: 01 Aug 2026 Review: 31 Jul 2027

1. Security Governance and Scope

This policy establishes the security baseline for NexaCore systems, employees, contractors, applications and information assets. The dataset is synthetic private-company data created for RAG evaluation and is not sourced from a real organization.

1.1 Security objectives

- Protect confidentiality of company and customer information.
- Preserve integrity of production systems and business records.
- Maintain availability of critical services within approved recovery targets.
- Detect and respond to security events using documented ownership and escalation.
- Apply least privilege and measurable access controls.

1.2 Information classification

Classification	Examples	Default handling
Public	Approved marketing material	External distribution permitted
Internal	Policies, engineering docs	Company access
Confidential	Contracts, source code, financial records	Need-to-know
Restricted	Credentials, security findings, regulated data	Explicit authorization + enhanced controls

1.3 Security ownership

The CISO delegate owns policy governance. Security Engineering operates preventive and detective controls. System owners remain accountable for security of the systems they operate.

2. Identity, Authentication and Access

2.1 Identity baseline

- Corporate identity is required for workforce access to managed systems.
- Multi-factor authentication is mandatory for production, administrative and remote access.
- Shared human accounts are prohibited except approved break-glass mechanisms.
- Service accounts must have an owner, documented purpose and credential rotation plan.
- Access must be removed or changed when employment or role status changes.

2.2 Authentication controls

Control	Requirement
MFA	Required for privileged and remote access
Password length	Minimum 14 characters where passwords are supported
Session timeout	15 min inactivity for privileged consoles
Privileged re-authentication	Every 12 hours or after risk event
Failed authentication monitoring	5 failures / 15 min triggers detection

2.3 Joiner / mover / leaver

Standard access changes should be completed within 4 business hours of an approved HR event. Terminated users with immediate security concern require access revocation as soon as the event is received.

3. Application and Infrastructure Security

3.1 Secure development

- Security requirements are reviewed for internet-facing and sensitive applications before production launch.
- Dependencies are scanned continuously; confirmed critical exposure is targeted for remediation within 24 hours.
- Secrets must be retrieved from approved secret management and must not be committed to source control.
- Production debug modes are prohibited.
- Security-sensitive actions require audit logging.

3.2 Infrastructure controls

Area	Minimum baseline
Network	Segment public ingress, workloads and data paths
Storage	Encryption at rest where supported
Transport	TLS for sensitive data in transit
Backups	Encrypted + access controlled
Administrative access	Privileged identity + MFA + logging
Endpoint	Managed device for privileged operations

3.3 Vulnerability severity

Reference remediation targets: Critical ≤ 24 hours, High ≤ 7 calendar days, Medium ≤ 30 calendar days, Low ≤ 90 calendar days.
Active exploitation can trigger emergency treatment regardless of severity label.

4. Data Protection and Monitoring

4.1 Data handling

- Restricted information may only be stored in approved systems.
- Customer data must not be copied to personal devices or unapproved collaboration tools.
- Production data used for development must be masked, minimized or replaced with synthetic data.
- Exports containing Confidential or Restricted information require approved destination and access controls.
- Data retention follows the corporate record schedule and applicable contractual requirements.

4.2 Logging requirements

Event	Minimum logging
Authentication	User/service, timestamp, result, source context
Privilege change	Actor, target, old/new privilege, timestamp
Security configuration change	Actor, object, change and result
Sensitive data access	Identity, resource and timestamp where supported
Incident action	Responder, action, time and ticket/reference

4.3 Monitoring

Security monitoring prioritizes authentication anomalies, privilege escalation, suspicious network behavior, malware indicators, data-exfiltration signals and unusual administrative activity.

5. Third-Party, Endpoint and Physical Controls

5.1 Third-party security

- Vendors handling Confidential or Restricted data require security due diligence before onboarding.
- Security review considers data types, access scope, incident notification, retention and subcontractors.
- Vendor access should be time-bounded where practical.
- Material security findings require an owner and remediation plan.

5.2 Endpoint baseline

Control	Baseline
Disk encryption	Required on managed laptops
Screen lock	≤10 minutes inactivity
OS updates	Critical security updates within 14 days; emergency faster when directed
EDR/endpoint protection	Required for managed corporate endpoints
Local administrator	Restricted; exception-based

5.3 Physical security

Restricted work areas, server infrastructure and security operations spaces require controlled entry. Visitors must be accompanied or registered according to site procedure.

6. Security Metrics, Exceptions and Review

6.1 FY26 security snapshot

Metric	FY26 value
Managed workforce devices	1,184
MFA coverage	98.7%
Privileged accounts reviewed quarterly	100%
Critical vulnerabilities identified	37
Critical vulnerabilities overdue at 31 Jul 2026	1
Security incidents requiring formal response	29
Mean time to acknowledge high-severity alerts	11 min
Phishing simulation reporting rate	76.4%
Third-party security reviews completed	143

6.2 Exceptions

Exceptions require business justification, risk statement, compensating control, owner, approver and expiry date. Security exceptions normally expire after 90 days unless renewed.

6.3 Governance

- Weekly vulnerability triage.
- Monthly security operations review.
- Quarterly privileged-access certification.
- Quarterly vendor-risk review for high-risk suppliers.
- Annual policy review and security-awareness refresh.

Document control

NC-SEC-POL-2026-08 | Version 5.3 | Next review 31 Jul 2027.